

DentalFlow

Las reglas que protegen a su clínica y a sus pacientes

Base de datos · Seguridad · Roles · Administración · Interfaz · Calidad

Este documento describe reglas que **ya funcionan hoy** en DentalFlow. Lo que todavía está en camino aparece separado al final. DentalFlow no declara certificaciones que no tiene: cada regla aquí es verificable en el sistema.

En una página

- **Nada se borra.** La historia clínica, las citas, los cobros y las cuentas solo se corrigen o anulan con motivo; todo queda auditado con quién y cuándo.
- **La base de datos manda.** Las reglas viven en la base, no solo en la pantalla: aunque alguien intente saltarse la app, no puede.
- **Cada quien ve lo suyo.** Doctor, recepción, asistente dental y admin tienen permisos distintos; cada clínica está aislada de las demás.
- **Acceso protegido.** Contraseñas fuertes, doble factor para admin y doctores, cierre por inactividad y respaldo nocturno cifrado.
- **Solo datos reales.** Nada inventado en pantalla: si no hay información, la app lo dice.

1. Principios del producto

Lo que DentalFlow promete a cada clínica, por encima de cualquier función.

Regla	Objetivo
Solo datos reales en pantalla	Todo número, lista o estado sale de la base de datos; si no hay datos, se dice.
Sin métricas, testimonios ni certificaciones inventadas	Confianza basada en hechos verificables.
Ningún botón decorativo	Si una función no existe todavía, no se muestra.
Pensado para clínicas de cualquier país	Ya incluye lo local donde empezó (cédula, ARS, exequátur, RD$); otros países se agregan después.
Español e inglés	Todo el equipo trabaja en su idioma.

2. Base de datos: la historia clínica no se pierde

Reglas impuestas por la propia base de datos (PostgreSQL / Supabase), no solo por la pantalla. Aunque alguien intente saltarse la app, la base no lo permite.

Regla	Objetivo
Nada clínico se borra	Pacientes y citas no tienen permiso de borrado: el paciente se archiva con motivo y la cita se cancela.
Registro clínico de solo escritura	Las notas clínicas solo se agregan y se leen; nunca se editan ni se borran.
Los errores se corrigen con una nueva entrada	Se enlaza a la entrada original con su motivo: queda la historia completa.
Autor y fecha los pone la base	Nadie puede firmar a nombre de otro ni cambiar la hora de un registro.
Auditoría de todo cambio	Se guarda versión anterior, nueva, quién y cuándo. Nadie puede escribir ni alterar la auditoría.
Toda tabla clínica nueva nace auditada y sin borrado	La regla aplica también al futuro, no solo a lo existente.

Regla	Objetivo
Seguridad por fila (RLS) en todas las tablas	Cada persona ve solo lo que su rol y su clínica permiten.
Visitantes sin sesión: cero acceso	Sin iniciar sesión no se lee ningún dato.
Nadie puede vaciar tablas (sin DELETE ni TRUNCATE)	Protege contra borrados masivos accidentales o maliciosos.
Funciones de la base con ruta fija y privilegios mínimos	Evita que se usen para escalar permisos.
Citas sin choques de horario	La base impide dos citas del mismo doctor a la misma hora.
Migraciones nuevas, nunca se editan las aplicadas	Historial de cambios de la base trazable y reproducible.

3. Varias clínicas, datos aislados

DentalFlow es multi-clínica: cada clínica es un espacio separado dentro de la misma plataforma.

Regla	Objetivo
Cada registro pertenece a una clínica	La base aísla las clínicas: una nunca ve datos de otra.
Pruebas automáticas de aislamiento	Se comprueba en cada versión que el aislamiento no se rompa.
Alta de clínica nueva desde la plataforma	Incorporar una clínica es un proceso controlado.
Clínica desactivada = usuarios bloqueados	Cortar el acceso de una clínica es inmediato y completo.
Cuentas creadas dentro de la clínica del admin	Un admin no puede crear usuarios en otra clínica.

4. Acceso y seguridad

Cómo se protege la entrada al sistema y la información en tránsito.

Regla	Objetivo
Contraseñas fuertes	Mínimo 10 caracteres con minúsculas, mayúsculas, números y símbolos.
Doble factor (MFA) para admin y doctores	Robar una contraseña no basta para entrar.
La base también exige el doble factor	Antes del segundo paso solo se puede leer el propio perfil.
Cierre de sesión por inactividad (15 min)	Una computadora olvidada en recepción no queda abierta.
Usuario desactivado pierde todo acceso al instante	Bloqueado en el login y sin permisos en la base.
Toda ruta pasa por el control de sesión	No hay páginas internas sin verificar al usuario.

Regla	Objetivo
Cabeceras de seguridad (HTTPS obligatorio, anti-clickjacking, etc.)	Protege contra ataques comunes del navegador.
Clave maestra solo en el servidor y tras comprobar admin	La llave con más poder nunca llega al navegador.
Consultas con columnas explícitas	Solo viaja la información necesaria.
Errores sin texto libre en la dirección web	Evita engaños y filtraciones por enlaces.
Respaldo nocturno cifrado y verificado	Si algo falla, los datos se recuperan.
Plan de respuesta a incidentes documentado	Pasos claros si hay una clave filtrada o una cuenta comprometida.
Revisión de seguridad documentada y alertas de dependencias	Las vulnerabilidades conocidas se vigilan.

5. Roles de la clínica

«Asistente dental» corresponde al rol de enfermería en el sistema. Los permisos se imponen en la base de datos, no solo ocultando botones.

Función	Admin	Recepción	Doctor	Asistente dental
Pacientes: crear	Sí	Sí	—	Sí
Pacientes: editar / archivar	Sí	Sí	—	—
Citas: crear, mover, cancelar	Sí	Sí	Solo estado de las suyas	—
Sala de espera	Toda la fila	Toda la fila	Sus turnos + «Llamar siguiente»	Ver
Registro clínico	Ve	Ve	Escribe	Escribe (sin medicamentos)
Medicamentos administrados	—	—	Sí	—
Odontograma	Ve	Ve	Escribe	Ve
Plan de tratamiento	Ve	Ve	Escribe	Ve
Signos vitales	Ve	Ve	Registra	Registra
Recetas	Ve	Ve	Receta y anula las suyas	Ve
Facturación	Registra	Registra	Ve	Sin acceso
Horarios	Sí	Sí	Sí	—
Análisis	Sí	—	Sí	—
Cuentas de usuario	Sí	—	—	—
Auditoría	Según lo que su rol ve	Ídem	Ídem	Ídem

6. Administración de cuentas

Lo que puede y no puede hacer el administrador de la clínica.

Regla	Objetivo
Solo el admin crea cuentas y cambia roles	Control centralizado de quién entra.
Las cuentas no se borran: se desactivan con motivo	Queda el historial de quién hizo qué.
Nadie cambia su propio rol ni se desactiva solo	Evita escalar privilegios.
Siempre al menos un admin activo	La clínica nunca queda sin administración.
El admin asigna el exequátur del doctor	Las recetas salen con datos profesionales correctos.
Cambios de cuentas auditados	Toda acción administrativa deja rastro.

7. Reglas de cada módulo clínico

Cómo se comporta cada parte de la historia del paciente.

Regla	Objetivo
Sala de espera: pasos válidos impuestos por la base	en espera → llamado → en atención → atendido (o cancelado); la base asigna la posición.
Odontograma: cada hallazgo firmado	Diente (FDI), superficies y condición; un error se anula con motivo.
Plan de tratamiento: estados controlados	pendiente → en proceso → completado, o cancelado con motivo; costo en RD$.
Plan → odontograma en un paso	Al completar un procedimiento el doctor registra el resultado en el diente.
Facturación con cobertura de ARS	La base calcula lo que paga el paciente y sigue el reclamo a la ARS.
Recibos con número consecutivo de la base	Numeración sin huecos ni duplicados.
Pagos y cargos se anulan, no se borran	Toda corrección deja rastro con motivo.
Un procedimiento, un cargo vigente	Evita cobrar dos veces lo mismo.
Signos vitales con alertas (AHA)	Avisa cuando hipertensión, diabetes o cardiopatía piden tomarlos.
Recetas firmadas con nombre y exequátur	Sin exequátur no se receta; aviso de alergias al medicamento.
Cédula validada (dígito verificador)	Evita errores de digitación.
Cédula repetida: avisa en vez de duplicar	Una sola ficha por paciente.
Horarios y días libres por doctor	Los huecos libres se calculan de la agenda real.

8. Interfaz (lo que ve el personal)

Reglas de pantalla pensadas para el ritmo real de una clínica.

Regla	Objetivo
Diseño congelado y consistente	El personal no tiene que reaprender la app con cada versión.
Paleta azul cielo; verde solo con significado	El color comunica estado (completado, diente sano).
Color teal reservado para la IA	Siempre se distingue qué propone la IA y qué decide el doctor.
Textos traducidos nunca tocan datos del paciente	Nombres y motivos se muestran tal como se guardaron.
Texto clínico mostrado de forma segura	Ningún dato guardado puede ejecutar código en el navegador.
Funciona en computadora y celular	Recepción en escritorio, doctor en el sillón.

Regla	Objetivo
Menú según el rol	Cada persona ve solo lo que puede usar.

9. Calidad y operación

Cómo se evita que un cambio rompa la clínica.

Regla	Objetivo
Pruebas automáticas de la lógica clínica y de cobro	Cédula, odontograma, plan, facturación, signos vitales, recetas, horarios, MFA.
Pruebas de extremo a extremo por rol	Se simula a cada rol usando la app y se verifica lo que puede y no puede hacer.
Pruebas solo en base local, nunca con datos reales	Los pacientes reales no se tocan al probar.
Toda versión compila y pasa revisión antes de publicarse	Menos errores en producción.
Cada cambio se revisa antes de unirse	Ningún cambio llega a producción sin aprobación del responsable.

10. En camino (todavía no disponible)

Separado a propósito: no se presenta como hecho lo que aún no lo está.

Mejora	Para qué
Dictado por voz → odontograma (en pausa)	La IA propone; el doctor revisa y firma. Nada se guarda sin él.
Bloqueo de contraseñas filtradas	Se activa al pasar al plan Pro del proveedor de base de datos.
Política de contenido (CSP) completa	Capa extra contra ataques en el navegador.